



Security Assessment



Item 8 Internal Report

August 2026

Prepared for ether.fi



Disclaimer

This document is intended for **internal** use only.



Initial Commit Hash	Final Commit Hash
72d0ae3e14	72d0ae3e14

Protocol Scope

- src/trading-safe/TradingSafeWithdrawModule.sol

Informational Issues

I-01. Exact-amount balance-delta check reverts on share-based rebasing tokens (e.g. stETH) due to internal rounding

Description: The post-transfer check in `TradingSafeWithdrawModule._withdrawExactAmounts` assumes a token's `balanceOf` decreases by exactly the transferred `amount`. Share-based rebasing tokens like stETH don't satisfy that: `transfer` internally converts `amount` to a floored share amount (`sharesToTransfer = floor(amount * totalShares / totalPooledEther)`), and `balanceOf` re-derives the ERC20-facing balance from shares via another division. The round-trip can leave the pre/post balance delta 1–2 wei short of the nominal `amount`, independent of any fee-on-transfer behavior. As a result, a legitimately signed, non-malicious withdrawal of stETH (`unwrap = false`) will revert with `WithdrawTransferFailed()` for most signed amounts. This does not affect the `unwrap = true` path, where the delta is checked on the ERC4626 vault share token, whose `redeem` burns the exact `shares` value passed in.

Recommendation: Consider documenting this behaviour so it is clear the module does not support such tokens

Customer's response: Acknowledged.

I-02. No output validation on unwrap redemptions — module checks shares burned, not assets received

Description: `redeem()`'s return value is never captured, and there's no `minAssetsOut` in `Withdrawal` or the signed digest. The only check is that the safe's share balance dropped by `w.amount` — nothing confirms the recipient actually received a corresponding amount of the underlying. Since the vault wraps a rebasing `xStock`, the exchange rate isn't fixed at signing time, and the permissionless relayer controls when the tx lands within the deadline window.

Recommendation: Consider adding a signed `minAssetsOut` per unwrap leg or at least consider documenting this for the users



Customer's response: Acknowledged.

Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.